

Warsaw, June 13, 2024

Decision

DKN.5131.57.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572) in connection with Articles 7, 60, and 102 § 1 point 1 and § 3 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) and Articles 57 § 1 letters a) and h), 58 § 2 letters d), e), and i), 83 § 1 and 2, 83 § 4 letter a) in connection with Articles 24 § 1, 25 § 1, 32 § 1 and 2, and 34 § 1, 2, and 4, as well as Article 83 § 5 letter a) in connection with Article 5 § 1 letter f) and § 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, as amended), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by the Independent Public Health Care Team based in P., ul. (...), the President of the Personal Data Protection Office, finding that the Independent Public Health Care Team based in P., ul. (...), violated the provisions of:

a) Article 24 § 1, Article 25 § 1, Article 32 § 1 and 2 of Regulation 2016/679, consisting of the failure to implement:

- appropriate technical and organizational measures to ensure the security of data processing in information systems and to protect the rights of data subjects, based on a risk analysis considering the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons,

- appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of personal data processed in information systems, particularly regarding vulnerabilities, errors, and their possible consequences for these systems and the actions taken to minimize the risk of their occurrence, resulting in a violation of the principle of integrity and confidentiality (Article 5 § 1 letter f of Regulation 2016/679) and the principle of accountability (Article 5 § 2 of Regulation 2016/679);

b) Article 34 § 1 of Regulation 2016/679, consisting of the failure to notify the data subjects of the breach of their personal data protection,

1) imposes on the Independent Public Health Care Team based in P., an administrative fine of 40,000 PLN (in words: forty thousand zlotys) for the violation of Article 5 § 1 letter f) and § 2, Article 25 § 1, Article 32 § 1 and 2, and Article 34 § 1 of Regulation 2016/679.

2) orders the Independent Public Health Care Team based in P., ul. (...) to notify, within 30 days from the date of delivery of this decision, the persons whose personal data were encrypted on the servers and other devices of the Independent Public Health Care Team based in P. due to the breach of personal data protection that occurred on February 10, 2022, about the breach of their personal data, in order to provide the required information, in accordance with Article 34 § 2 of Regulation 2016/679, i.e.:

a) a description of the nature of the personal data breach;

b) the name and contact details of the data protection officer or another contact point from which more information can be obtained;

c) a description of the possible consequences of the personal data breach;

d) a description of the measures taken or proposed by the Administrator to address the breach – including measures to minimize its potential negative effects.

3) orders the Independent Public Health Care Team based in P., ul. (...), to adjust the processing operations to the provisions of Regulation 2016/679 by implementing appropriate technical and organizational measures to ensure the security of data processing in information systems to minimize the risks associated with the processing of personal data, particularly arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed, after conducting a risk analysis considering the state of

technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons, within 90 days from the date of delivery of this decision.

Justification

The Independent Public Health Care Team based in P. (hereinafter referred to as: the Administrator or SPZOK in P.) reported on February 16, 2022, to the President of the Personal Data Protection Office (hereinafter also referred to as: the President of the Office) a breach of personal data protection that occurred on February 10, 2022. The above breach consisted of the encryption of data.

SPZOK in P. was affected by malicious software known as "ransomware." Consequently, the Administrator was deprived of access to the data stored on the servers and (...), where the database of SPZOK in P. is located.

The scope of personal data involved in the aforementioned breach, according to the notification of the personal data breach, included first name and surname, parents' names, date of birth, bank account number, residential or temporary address, PESEL number, username and/or password, income or asset data, mother's maiden name, series and number of the identity card, phone number, and health-related data.

The Administrator indicated that the servers affected by the personal data breach contained data of 30,331 patients of SPZOK in P. as well as data of 1,129 employees, contractors, and collaborators of SPZOK in P.

In light of the above incident, the Administrator did not determine a high risk of infringement of the rights or freedoms of natural persons, as according to his findings, the data on the servers and virtual machines affected by the breach were not stolen, read, or disclosed. This was established as a result of an expert assessment conducted after the occurrence of the personal data breach, within which it was determined that (...). Therefore, the Administrator did not notify the individuals whose data were affected about the breach of their personal data.

In letters dated February 17, 2022, August 8, 2022, November 2, 2022, March 14, 2023, April 24, 2023, and December 14, 2023, the President of the Office requested SPZOK in P. to provide explanations regarding this matter. Based on the notification of the personal data breach and the responses provided in letters dated March 4, 2022, August 12, 2022, November 14, 2022, March 27, 2023, May 10, 2023, and January 15, 2024, the following factual state was established:

1. On February 10, 2022, a breach of personal data protection was identified at the Independent Public Healthcare Team, manifested by the encryption of data stored on servers and virtual machines, where the database of SPZOK in P. is located. The aforementioned breach occurred during the night of February 9 to 10, 2022. Data on the server disks (...), where backup copies were stored, as well as data on (...) were encrypted.
2. Apart from notifying the President of the Office about the incident, the Police were also informed. The investigation is being conducted by the District Police Headquarters in P. along with the (...) Department of the Voivodeship Police Headquarters in (...). During the ongoing investigation, the Police secured most of the IT equipment of SPZOK in P., including (...), which, in the opinion of the Administrator, prevented the conduct of an internal explanatory procedure.
3. In connection with the incident, SPZOK in P. commissioned an external entity to conduct an assessment in order to attempt to decrypt the data in the form of (...) originating from the Administrator's servers. The above assessment, dated (...) February 2022, established that the encryption was caused by ransomware software (...). Furthermore, as indicated in the content of the assessment, (...). The authors of the study also indicated that currently there are no decryption tools available for the (...) ransomware software; however, such tools may become available in the future. In the Administrator's opinion, the above assessment also demonstrated that (...).
4. The Administrator also commissioned an external entity to conduct an IT security audit, aimed at (...). This audit revealed, among other things, that (...).

5. In the Administrator's opinion, the backup copy was being made at SPZOK in P. using the R. tool in a manner (...), on which the O. server was located (...), then (...) on the N. server of brand Q. The testing of the backup copies was conducted using the R. tool. However, as the aforementioned assessment showed, (...).

6. The Administrator was unable to recover the encrypted data, including the backup copies.

7. After the occurrence of the personal data breach, the Administrator took a number of actions to minimize the risk of such breaches occurring in the future, such as conducting further security audits (the Administrator sent confirmations of such audits dated: (...) March 2022, (...) November 2022, and (...) September 2023), as well as conducting training for employees in the field of cybersecurity, and purchasing and configuring (...).

8. SPZOK in P. does not have evidence confirming the conduct of risk analyses for personal data processing operations prior to the occurrence of the personal data breach. At the same time, the Administrator indicated that he does not have evidence confirming the regular testing, measuring, and evaluating of the effectiveness of technical measures aimed at ensuring the security of processing prior to the occurrence of the personal data breach.

9. At SPZOK in P. prior to the occurrence of the personal data breach, there was no procedure for updating systems and software of IT devices. The current update of systems and software of IT devices was conducted by (...) employed under an employment contract. The f. software at the time of the occurrence of the personal data breach was updated to the latest version — SPZOK in P. then had (...).

10. An "Instruction (...)" was developed at SPZOK in P., which constitutes Annex No. (...) to P. (...) regarding the processing of personal data.

In connection with the reported personal data breach and the explanations provided by the Administrator, the President of the Office for Personal Data Protection...

Personal Data Protection Authority on May 17, 2023, initiated ex officio administrative proceedings (case no. (...)) regarding the possibility of a violation by SPZOK in P., as the data controller, of the obligations arising from the provisions of Article 5(1)(f), Article 24(1), Article 32(1) and (2), and Article 34(1) of Regulation 2016/679. Subsequently, by a letter dated October 27, 2023, the President of the Office expanded the above administrative proceedings to include the possibility of a violation by SPZOK in P., as the data controller, of the provisions of Article 5(2) and Article 25(1) of Regulation 2016/679.

The administrator did not respond to the letter notifying about the initiation of the administrative proceedings, nor to the letter informing about the expansion of these proceedings. After reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:

Article 5 of Regulation 2016/679 formulates principles regarding the processing of personal data that must be respected by all controllers, i.e., entities that determine the purposes and means of processing personal data either alone or jointly with others. According to Article 5(1)(f) of the aforementioned regulation, personal data must be processed in a manner that ensures appropriate security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("confidentiality and integrity"). Furthermore, according to Article 5(2) of Regulation 2016/679, the controller is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance ("accountability").

In accordance with Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity, the controller implements appropriate technical and organizational measures to ensure that processing is performed in accordance with the specified

regulation and to be able to demonstrate this. These measures are reviewed and updated as necessary.

Pursuant to Article 25(1) of the aforementioned regulation, taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity arising from processing, the controller—both when determining the means of processing and during the processing itself—implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide the necessary safeguards for processing to meet the requirements of this regulation and protect the rights of data subjects.

As indicated by the European Data Protection Board (EDPB) in Guidelines No. 4/2019 on Article 25 “Data Protection by Design and by Default” Version 2.0, p. 4 (hereinafter: Guidelines No. 4/2019), Article 25(1) of Regulation 2016/679 states that “(...) controllers should consider data protection by design and by default at an early stage, during the planning of the next processing operation. They implement data protection by design and by default prior to processing, as well as continuously during processing, conducting regular reviews of the effectiveness of the selected measures and safeguards. Data protection by design and by default also applies to existing systems that process personal data.” This means that existing systems designed before the entry into force of Regulation 2016/679 should be subject to reviews and maintenance to ensure the implementation of measures and safeguards that effectively enforce the principles and rights of data subjects, as specified in the aforementioned guidelines.

From the content of Article 32(1) of Regulation 2016/679, it follows that the controller is obliged to implement technical and organizational measures that correspond to the risk of infringement of the rights and freedoms of natural persons of varying likelihood and severity of threat. The provision specifies that when deciding on technical and organizational measures, one must take into account the state of the art, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity. The cited provision indicates that determining appropriate technical and organizational measures is a two-step process.

Firstly, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32(1) of the aforementioned regulation, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to restore the availability of personal data and access to it quickly in the event of a physical or technical incident, and regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing. According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the controller takes into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, ****Loss, Modification, Unauthorized Disclosure or Unauthorized Access to Personal Data****

Transmitted, Stored or Otherwise Processed.

According to Recital 75 of the preamble to Regulation 2016/679, the risk of infringement of the rights or freedoms of natural persons, with varying probabilities and severity, may arise from the processing of personal data that could lead to physical harm or material or non-material damage, in particular:

- if the processing may result in discrimination, identity theft or identity fraud, financial loss, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm;
- if the data subjects may be deprived of their rights and freedoms or the ability to exercise control over their personal data;
- if personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or

trade union membership are processed, and if genetic data, health data, or data concerning sexual orientation or criminal convictions and related security measures are processed;

- if personal factors are assessed, in particular, aspects concerning work performance, economic situation, health, personal preferences or interests, reliability or behavior, location or movement - for the purpose of creating or using personal profiles; or if data of individuals requiring special protection, in particular children, are processed, and if the processing concerns a large amount of personal data and affects a large number of data subjects.

The legislator indicates through Recital 76 of the preamble to Regulation 2016/679 that the probability and severity of the risk of infringement of the rights or freedoms of the data subject should be determined by reference to the nature, scope, context, and purposes of the data processing. The risk should be assessed based on an objective evaluation, within which it is determined whether the data processing operations involve risk or high risk.

Recital 83 of the preamble to Regulation 2016/679 indicates, on the other hand, that in order to maintain security and prevent processing that is inconsistent with Regulation 2016/679, the controller should assess the risk specific to the processing and implement measures - such as encryption - to minimize that risk. In assessing the risk regarding data security, the risks associated with the processing of personal data should be taken into account - such as accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed - which may in particular lead to physical harm, material or non-material damage.

Taking into account in particular the scope of personal data processed by the SPZOZ in P., in order to properly fulfill the obligations imposed by the aforementioned provisions of Regulation 2016/679, the Administrator was obliged to take actions ensuring an appropriate level of data protection by implementing appropriate technical and organizational measures, as well as actions aimed at the required security of the information systems used. The nature and type of these actions should result from a conducted risk analysis, in which vulnerabilities related to the resources used and the threats arising from them should be identified, and then appropriate security measures should be determined. Incorrect risk assessment prevents the application of appropriate security measures for a given resource and increases the likelihood of its occurrence. The result of the above was the materialization of the risk, resulting in a breach of the security of the Administrator's information system, used by him for processing personal data, and subsequently the encryption of the data processed therein using malicious software.

As follows from the evidence gathered in the case, the Administrator is unable to demonstrate or confirm that a risk analysis for the processing of personal data was conducted prior to the occurrence of the personal data breach. In the course of explanations, the Administrator indicated that he does not possess documentation confirming the execution of such an analysis, while the person responsible for the security of personal data was (...) employed under an employment contract, who continuously analyzed, among other things, vulnerabilities, threats, possible consequences of breaches, and security measures aimed at ensuring the confidentiality, integrity, and availability of processed personal data.

In the assessment of the supervisory authority, such a manner of operation by the SPZOZ in P. did not ensure adequate control over the aforementioned process in the context of guaranteeing the security of the personal data involved, as well as the ability to demonstrate its compliance with the provisions of Regulation 2016/679, in accordance with the accountability principle resulting from Article 5(2) of the aforementioned regulation.

As has already been raised in the literature (P. Barta, P. Litwiński, M. Kawecki, Commentary on Article 5, in: General Regulation on Personal Data Protection. Data Protection Act. Selected Sectoral Provisions. Commentary, ed. P. Litwiński, Legis 2021), "accountability, which in particular is the obligation to demonstrate compliance with legal provisions, consists in the opinion of the Article 29 Working Party [Opinion of 13.7.2010 No. 3/2010 on the principle of accountability."

(WP 173), (...) from the following partial obligations:

- 1) the obligation to implement measures (including internal procedures) that guarantee compliance with data protection regulations in relation to their processing operations;
- 2) the obligation to prepare documentation that indicates to the data subjects and supervisory authorities what measures have been taken to ensure compliance with personal data protection regulations.

(...) In this sense, accountability should therefore be understood as a certain property of processing activities, allowing for the demonstration of compliance with legal regulations concerning operations on personal data, particularly through documentation of personal data protection. The consequence of the principle of accountability is that in the event of a dispute with the data subject or with the supervisory authority, the controller should be able to present evidence that they comply with personal data protection regulations. Such evidence may primarily consist of documents describing the principles of processing and protecting personal data.

Due to the lack of a risk analysis associated with the processing of personal data, the SPZOK in P. is unable to demonstrate that, in implementing technical and organizational measures to ensure compliance with Regulation 2016/679, and also assessing whether the level of security of personal data is appropriate, the criteria described in Article 32(1) of Regulation 2016/679 were actually taken into account, including the risk of infringement of the rights or freedoms of natural persons, and the risks associated with processing, particularly those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data, in accordance with the obligation arising from Article 32(2) of Regulation 2016/679. As emphasized by the Provincial Administrative Court in Warsaw in its judgments of May 13, 2021, case file II SA/Wa 2129/20, and October 5, 2023, case file II SA/Wa 502/23, "the data controller should therefore conduct a risk analysis and assess what threats they are dealing with."

The obligation to ensure the security of processed data, specified among others in Article 32(1) of Regulation 2016/679, is one of the legal bases for the protection of personal data introduced by Regulation 2016/679. The applicable legal provisions do not specify a catalog of appropriate security measures, and it is the responsibility of the controller to assess this area. This provision introduces a risk-based approach, indicating the criteria based on which the controller should select appropriate technical and organizational measures to ensure a level of security corresponding to that risk. In addition to the risk of infringement of the rights or freedoms of natural persons, the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing should also be taken into account. As indicated by the Provincial Administrative Court in its judgment of October 5, 2023, case file II SA/Wa 502/23, "the supervisory authority is not obliged to indicate to the Controller the technical and organizational solutions that they should implement to ensure that the processing of personal data is carried out in accordance with the law. It is the responsibility of the Controller to implement these measures and then, if necessary, demonstrate that they comply with the principles of personal data processing specified in Regulation 2016/679, in accordance with the principle of accountability (Article 5(2) of the aforementioned regulation)."

As demonstrated by the report from the audit conducted at SPZOK in P. dated (...) March 2022, (...). As indicated in this report: "...". Such conduct is in obvious contradiction to the norms formulated in the content of Regulation 2016/679, which at every stage of implementing the IT system for processing – both in the design, implementation, maintenance, or modification phases – foresee the consideration of the risks associated with these operations that may infringe the rights or freedoms of natural persons. In Guidelines No. 4/2019 (p. 29), the EDPB indicates that "the assessment of threats to data security involving an analysis of the impact on the rights of natural persons and counteracting identified threats," "considering security requirements at the earliest stage of system design and development and continuous integration and execution of appropriate tests," or "regular review and testing of software, hardware, systems, and services, etc., to detect weaknesses in the systems supporting processing" are among the key elements of incorporating data protection in the design phase and default data protection.

Following the statement of the Provincial Administrative Court in Warsaw contained in the judgment of January 19, 2021 (case file II SA/Wa 702/20, Legalis No. 2821108), it should be emphasized that "(...) the data controller should adequately secure personal data against accidental loss using appropriate technical and organizational measures. Personal data should be processed in a manner that ensures appropriate security and confidentiality, including protection against unauthorized access to them and to the equipment used for their processing, as well as against unauthorized use of such data and equipment (Recital 39 of Regulation 2016/679). (...) the data controller is responsible not only for the actions of their employees but also for the processing of data in the IT system they use."

Referring to the explanations provided by the Controller on January 15, 2024, it should be emphasized that the argumentation contained in the aforementioned letter, that (...) employed at the time of the infringement analyzed all vulnerabilities and risks in SPZOZ in P. regarding security, suggesting that the mere fact of performing...

The above-mentioned employee's fulfillment of their duties is unequivocally linked to meeting the requirements mentioned above, which is unacceptable. It should be emphasized that it is the Administrator's role to demonstrate compliance with the provisions of Regulation 2016/679 (Article 5(2)) before the supervisory authority. Currently, in this regard, the administrator is unable to prove that they have fulfilled the obligations imposed on them by the aforementioned regulations.

The IT security audit conducted within the Administrator's organization revealed, among other things, that (...). Furthermore, this audit uncovered a number of other irregularities regarding the security of information systems. It was indicated, among other things, that (...). It was noted that in the case of (...). It was emphasized that the Administrator (...). Also, in the explanations submitted within the framework of the proceedings (dated January 15, 2024), it was indicated that prior to the occurrence of the personal data breach, there was no procedure in place at SPZOZ in P. for (...).

An extremely important element for assessing the implemented technical measures is the consideration of the necessity for periodic backups of databases from servers. The discussed report clearly indicates that (...). Moreover, it should be noted that backups, which should constitute one of the most important areas for maintaining operational continuity for any organization, were also encrypted in the context of the personal data breach. As indicated by the Administrator, the encrypted data from the backups could not be decrypted, which consequently means that SPZOZ in P. did not implement solutions aimed at continuously ensuring the availability of processing systems and services, as well as the ability to quickly restore access to personal data and access to it in the event of a physical or technical incident, which it was obliged to do in accordance with the requirements of Article 32(1)(b) and (c) of Regulation 2016/679.

Equally importantly, the Administrator was fully aware of the obligations resting upon them in this regard. This is evidenced, among other things, by the provisions contained in the "Instruction (...)," which explicitly stated that (...).

The analysis of the above document allows us to conclude that the lack of regular backups by the Administrator constituted not only a violation of the provisions of Regulation 2016/679 but also a breach of internal regulations aimed at ensuring the proper and secure processing of personal data within the organization.

As indicated by the gathered evidence, SPZOZ in P. is also unable to document or otherwise prove that prior to the occurrence of the personal data breach, it was regularly testing, measuring, and assessing the effectiveness of the technical and organizational measures intended to ensure the security of personal data processing. Such actions were taken only after the incident, as indicated by the reports from the conducted security audits dated (...) March 2022, (...) November 2022, and (...) September 2023.

It should be noted that administrators are obliged not only to achieve compliance with the guidelines of Regulation 2016/679 through a one-time implementation of technical and organizational security measures but also to ensure the continuity of monitoring the scale of threats and accountability regarding the level and adequacy of the implemented safeguards. Representatives of doctrine

emphasize that “(...) the obligation to ensure appropriate technical and organizational measures, as referred to in Article 32(1) [of Regulation 2016/679], is dynamic (...), as the EU legislator requires regular testing, measuring, and assessing the effectiveness of the measures applied to ensure security to a degree commensurate with the risk” (P. Barta, P. Litwiński, M. Kawecki, Commentary on Article 32, in: General Regulation on Data Protection. Data Protection Act. Selected Sectoral Provisions. Commentary, ed. P. Litwiński, Legalis 2021).

It is worth emphasizing that the aforementioned testing, measuring, and assessing of technical and organizational measures intended to ensure security in processing must be carried out regularly, which means consciously planning and organizing, as well as documenting such actions within specified time frames, regardless of changes in the organization and the course of data processing processes (in connection with the accountability principle referred to in Article 5(2) of Regulation 2016/679). Indeed, the copies of the security audit reports submitted by SPZOZ in P. within the framework of the submitted explanations confirm (...), as mentioned above, but only after the occurrence of the personal data breach. The discussed allegation pertains to the situation that occurred within the Administrator's organization prior to the determination of the subject breach, when regular testing, measuring, and assessing the effectiveness of technical and organizational measures were not conducted.

Undoubtedly, undertaking these actions before its occurrence would have contributed to identifying gaps in security, at least to the extent indicated in the audit from (...) 2022, and consequently would have allowed the Administrator to take action to eliminate them. As indicated by the Provincial Administrative Court in Warsaw in its judgment of June 6, 2023, case file II SA/Wa 1939/22, “(...) the obligation of regular testing of technical and organizational measures securing the processing of personal data, to ensure a level of security commensurate with the risk, in the sense of Article 32(1) introductory sentence of the GDPR, directly arises from the wording of point d of the indicated Article 32(1), while the obligation to document actions in a given...

the principle of accountability is established (Article 5(2) of the GDPR)”. Similarly, the Provincial Administrative Court in Warsaw stated in its judgment of June 21, 2023, case file II SA/Wa 150/23. The lack of risk analysis resulting in the selection of inappropriate security measures and the absence of regular testing, measuring, and evaluating by the SPZOZ in P. the effectiveness of the implemented technical and organizational measures aimed at ensuring the security of processing not only led to a violation of personal data protection, as referred to in Article 4(12) of Regulation 2016/679, but also determined the breach by SPZOZ in P. of the obligations imposed on the data controller, arising from Article 24(1), Article 25(1), Article 32(1), and Article 32(2) of Regulation 2016/679, and consequently also the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679. The effect of the breach of the principle of confidentiality is the violation of Article 5(2) of Regulation 2016/679. As indicated by the Provincial Administrative Court in Warsaw in its judgment of February 10, 2021 (case file II SA/Wa 2378/20, Legalis No. 2579568), “(...) the data controller is responsible for complying with all principles when processing personal data (listed in Article 5(1)) and must be able to demonstrate compliance. The principle of accountability is therefore based on the legal responsibility of the controller for properly fulfilling obligations and imposes on them the duty to provide evidence of compliance with all data processing principles both to the supervisory authority and to the data subject.” The Provincial Administrative Court in Warsaw interpreted this issue similarly in its judgment of August 26, 2020 (case file II SA/Wa 2826/19, Legalis No. 2480051), stating that “considering the entirety of the provisions of Regulation 2016/679, it should be emphasized that the controller has significant discretion regarding the security measures applied, while at the same time bearing responsibility for violations of personal data protection regulations. The principle of accountability directly implies that it is the controller who should demonstrate, and thus prove, that they comply with the provisions specified in Article 5(1) of Regulation 2016/679.” Only after the occurrence of a personal data breach did the Administrator undertake certain technical-organizational actions, including: (...). However, these actions were not preceded by a risk analysis, which means that the Administrator is unable to ascertain or demonstrate that the aforementioned security measures are appropriate and will ensure the protection of the processed personal data, including health data, adequate to the risks associated with their processing by an entity providing health care services. According to the definition

contained in Article 4(12) of Regulation 2016/679, “a personal data breach” is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed. As stated in Article 34(1) of Regulation 2016/679, if a personal data breach is likely to result in a high risk of adversely affecting the rights or freedoms of natural persons, the controller shall without undue delay notify the data subject of such a breach. In paragraph 2 of the aforementioned article, it is indicated that the notification referred to in paragraph 1 shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33(3)(b), (c), and (d) of the aforementioned regulation, where it is specified that such notification must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects concerned, as well as the categories and approximate number of personal data records concerned by the breach; b) contain the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the likely consequences of the personal data breach; d) describe the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects. As explained by the Administrator during the proceedings, the data subjects were not notified of the personal data breach because, in their opinion, the encryption of the data did not pose a high risk to the rights or freedoms of natural persons. Additionally, the Administrator indicated that the data on the servers and virtual machines affected by the breach had not been stolen, read, or disclosed. However, it should be noted that the expert opinion conducted outside of the proceedings on (...) February 2022, commissioned by the Administrator, indicates only that “(...)”. There is, however, a lack of information clearly indicating that the encrypted data had not been previously read or downloaded. Consequently, it should be assumed that the person or persons who encrypted the data could or may still obtain unauthorized access to it. This is evidenced, among other things, by the content of the message sent from the attackers to the Administrator, where, in order to substantiate their intentions and capabilities, they proposed decrypting one of the encrypted files without charging a fee. In the event of non-compliance with the demand to purchase the device (decoder) specified by the attackers for decryption, they threatened to publish the relevant data online. The consequences resulting from the described attack, as the content of the above message directed to the Administrator, as well as the lack of unequivocal findings in this regard resulting from the extrajudicial expertise dated (...) February 2022, raises justified concerns that within the framework of this incident, there was not only a loss of availability of personal data but also a breach of the confidentiality of that data. As stated in Article 33(5) of Regulation 2016/679, the administrator documents all breaches of personal data protection, including the circumstances of the breach, its consequences, and the remedial actions taken. Based on the content of the aforementioned provision in connection with the principle of accountability described in Article 5(2) of the same regulation, it should be assumed that the burden of proof lies with the Administrator to demonstrate that the attackers did not seize (did not copy) the databases of SPZOK in P. Therefore, considering the explanations provided by the Administrator and the nature and type of the hacking attack, which is ransomware, it should be stated that SPZOK in P. has not unequivocally demonstrated that there was no breach of data confidentiality in the discussed case. The Administrator, at the stage of providing explanations, as well as after the initiation of administrative proceedings, was unable to prove (demonstrate indisputably) that there was no disclosure of data subject to the breach, and thus a breach of their confidentiality.

Consequently, due to the ongoing risk of disclosure of personal data from the databases of SPZOK in P., it should be assumed that there is a high risk of violation of the rights and freedoms of the employees and patients of the aforementioned entity, resulting in the obligation to notify them, as referred to in Article 34 of Regulation 2016/679.

Referring to the loss of availability, it should be noted that the loss of access to data that occurred in this case, especially given the nature of the activities conducted by the Administrator and the lack of possibility to quickly restore the encrypted personal data due to the encryption of backup copies as well, considering the scope and type of personal data processed within this activity, may realistically

affect the rights or freedoms of the individuals whose data is concerned. In SPZOZ in P., personal data of patients is processed, including data that belongs to special categories of personal data, i.e., data concerning health. The lack of access to this data poses a risk of limited access to medical documentation, which may significantly hinder or even prevent the proper provision of medical services to a specific individual, which consequently creates a real risk to the health and even life of the patient.

The above indicates that the Administrator currently has no control over the encrypted data, especially since this data has not been ultimately recovered by him. Such a situation poses very serious risks and threats to the rights or freedoms of individuals whose data was processed on the attacked computers and (...). Consequently, it creates a high risk of violation of the rights or freedoms of individuals, which means the obligation to notify these individuals about the breach of their personal data protection.

It should also be emphasized that the breach of personal data protection that occurred involved the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies an individual, containing, among other things: date of birth and gender designation, and thus is closely related to the private sphere of the individual and is also subject to exceptional protection under Article 87 of Regulation 2016/679, being data of a special nature and requiring such special protection. The PESEL number serves as an identifying data for each person and is commonly used in dealings with various institutions and in legal circulation. The PESEL number, along with the first name and surname, uniquely identifies an individual in a way that allows for the attribution of negative consequences of a breach (e.g., identity theft, loan fraud) to that specific person. Therefore, it should be taken into account that the subject of the discussed breach of personal data protection includes, among other things, data in the form of the identification number along with the first name and surname, which combination of data may be sufficient to "impersonate" the subject of that data and incur obligations in the name and to the detriment of such a subject, e.g., financial obligations (see: <https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> - where a case is described in which: "Only the first name, surname, and PESEL number were enough for the fraudsters to defraud several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the address of residence"). It is also impossible to overlook that the analyzed breach of personal data protection also involved contact details, which are commonly understood to include, among other things, the address of residence or stay and phone number, as well as data such as bank account number or series and number of the ID card, and, as already mentioned above, data concerning health status. These data, as a whole, in a general sense constitute a certain type of collection, while as emphasized in the EDPB Guidelines No. 9/2022[1], a collection of various personal data usually has a more sensitive nature than individual data. In assessing the risk, the type and sensitivity of the personal data disclosed as a result of the breach is a key factor. There is also no doubt that such a range of data allows for the unequivocal identification of a person.

It is worth quoting one of the examples found in the Guidelines of the European Data Protection Board 01/2021[2] (case No. 14, p. 31), relating to the situation of "sending highly confidential personal data by mistake by mail." In the described...

www. In the guidelines, it was revealed that the social security number, which is equivalent to the PESEL number used in Poland, was disclosed. In this case, the EROD had no doubts that the disclosed data, including: first name and surname, email address, postal address, and social security number, indicated a high risk of violation of the rights or freedoms of individuals ("the involvement of their [the affected individuals'] social security number, as well as other, more fundamental personal data, further increases the risk, which can be described as high"). The EROD recognizes the importance of national identification numbers (in this case, the PESEL number), while emphasizing that this type of personal data breach, therefore encompassing data in the form of: first name and surname, email address, postal address, and social security number, requires the implementation of actions, i.e.: notifying the supervisory authority and informing the affected individuals about the breach.

The European Data Protection Board has no doubt that an individually assigned number that uniquely identifies a natural person should be subject to special protection, and its disclosure to unauthorized entities may involve a high risk of violation of the rights or freedoms of individuals.

The fact that data that uniquely identifies a natural person may cause a high risk of violation of rights or freedoms is also indicated by the EROD in other examples provided in Guidelines 01/2021. In points 65 and 66 of the cited Guidelines, it was stated: "(...) The breached data allows for the unequivocal identification of the individuals concerned and contains other information about them (including gender, date and place of birth); moreover, it may be used by an attacker to guess customers' passwords or to conduct a spear-phishing campaign directed at bank customers. For these reasons, it was concluded that the data breach is likely to result in a high risk of violation of the rights and freedoms of all individuals whose data is concerned. Consequently, material damages (e.g., financial losses) and non-material damages (e.g., identity theft or fraud) may occur."

Furthermore, it should be noted that the subject data breach also included data concerning the health of patients, including children and individuals with special needs (e.g., elderly persons, persons with disabilities, etc.). It is important to emphasize that this data falls within the sphere of information related to the patient, obtained by the doctor in connection with the performance of their profession, and as such is subject to the obligation of confidentiality. Equally important, health data, according to Regulation 2016/679, belongs to special categories of personal data and is subject to specific processing rules and should be afforded special protection by their administrators, and in the event of a personal data breach, it creates a high risk of violation of the rights or freedoms of a natural person.

Therefore, there is no doubt that the breach discussed in this case, due to the scope of data processed by the Administrator, poses a high risk of violation of the rights or freedoms of a natural person.

It should be emphasized that the assessment of the risk of violation of the rights or freedoms of a natural person should be made through the lens of the affected individual, not the interests of the administrator. This is particularly important because based on the notification of a personal data breach, the individual can assess for themselves whether, in their opinion, the security incident may have negative consequences for them and take appropriate remedial actions. Also, based on the information provided by the administrator regarding the description of the nature of the breach and the measures taken or proposed to remedy the breach, the individual can assess whether, after the breach occurred, the data administrator still guarantees the proper processing of their personal data in a manner that ensures its security. The lack of notification of a personal data breach to the individual in the event of a high risk of violation of their rights or freedoms deprives them not only of the opportunity to respond appropriately to the breach but also of the ability to independently assess the breach, which, after all, concerns their personal data and may have serious consequences for them. On the other hand, the lack of reporting a personal data breach deprives the supervisory authority of the ability to respond appropriately to the breach, which involves not only assessing the risk of violation of the rights or freedoms of a natural person but also, in particular, verifying whether the administrator has taken appropriate measures to remedy the breach and minimize the negative effects for the individuals concerned, as well as whether appropriate security measures have been implemented to minimize the risk of recurrence of the breach.

Notifying individuals about the breach provides the opportunity to convey information to those individuals about the risks associated with the breach and to indicate actions that those individuals can take to protect themselves from potential negative consequences of the breach (this enables the individual to make an independent assessment of the breach in the context of the possibility of materializing negative consequences for such an individual and to decide whether to take or not take remedial actions).

As a result of the analysis of the breach that occurred, the categories of data, and the categories of individuals it concerned, the President of the Personal Data Protection Office concluded that the breach of confidentiality and availability of data (due to the inability to decrypt the data and the possibility of access to it by the perpetrators of the breach...

****Personal Data Protection****

The processing of personal data, particularly concerning names and surnames as well as PESEL numbers along with health-related data, poses a high risk of infringement of the rights or freedoms of

natural persons. Therefore, it is necessary to promptly and correctly notify the individuals whose data is affected about the breach of their personal data. Consequently, it should be stated that the Administrator did not notify the individuals whose data is affected about the breach of their data protection, in accordance with Article 34(1) of Regulation 2016/679, which constitutes a violation of this provision by the Administrator.

At this point, it should be noted that according to Article 34(4) of Regulation 2016/679, if the administrator has not yet notified the individual whose data is affected about the breach of personal data protection, the supervisory authority—taking into account the likelihood that this breach of personal data protection will result in a high risk—may require the administrator to do so or may determine that one of the conditions referred to in paragraph 3 has been met. Furthermore, from the content of Article 58(2)(e) of Regulation 2016/679, it follows that each supervisory authority has the corrective power to order the administrator to notify the individual whose data is affected about the breach of data protection. In this regard, the Administrator has been obliged by the President of the Office to notify, within 30 days from the date of delivery of this decision, the individuals whose data was processed in the resources of the attacked devices about the breach of their personal data protection in order to provide these individuals with the required information in accordance with Article 34(2) of Regulation 2016/679.

Based on Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a) - (h) and (j) of this Regulation, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the factual findings, the President of the Personal Data Protection Office, exercising the authority granted to him under the aforementioned provision of Regulation 2016/679, determined that in the case at hand, there were grounds justifying the imposition of an administrative fine on the Independent Public Healthcare Team based in P.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the administrator and the processor, as referred to in Articles 8, 11, 25-39, and 42 and 43, are subject, according to paragraph 2, to an administrative fine of up to 10,000,000 EUR, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. Furthermore, according to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, as referred to in Articles 5, 6, 7, and 9, are subject, according to paragraph 2, to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Moreover, Article 102(1)(1) of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the uodo, states that the President of the Office may impose, by way of a decision, administrative fines of up to 100,000 PLN on: entities in the public finance sector, as referred to in Article 9(1-12 and 14) of the Act of August 27, 2009, on Public Finances, research institutes, or the National Bank of Poland. Paragraph 3 of this article further states that administrative fines, as mentioned in paragraph 1, are imposed by the President of the Office based on and under the conditions specified in Article 83 of Regulation 2016/679.

In deciding to impose an administrative fine, the President of the Office—according to the provisions of Article 83(2)(a) - (k) of Regulation 2016/679—considered the following circumstances of the case, which necessitate the application of this type of sanction in the present case and influence the severity of the imposed administrative fine:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679).

The infringement of the provisions of Regulation 2016/679 identified in this case, resulting in the breach of personal data stored on servers and virtual machines where the database of SPZOZ in P. was located, is of significant weight and serious nature, as it creates a high risk of negative legal

consequences for a potentially large number of individuals (the Administrator indicated that the servers contained data of 30,331 patients of SPZOZ in P. as well as data of 1,129 employees, contractors, and collaborators of this entity), to whose data access was lost. The failure of SPZOZ in P. to fulfill its obligations to apply security measures to protect the processed data from being disclosed to unauthorized persons entails not only a potential but also a real possibility of misuse of this data by third parties without the knowledge and against the will of the individuals whose data is concerned, contrary to the provisions of Regulation 2016/679, for example, for the purpose of establishing legal relations or incurring obligations on behalf of the individuals whose data is concerned. The significant nature and gravity of the described infringement of the provisions of Regulation 2016/679 is also determined by the fact that this infringement concerns, among other things, personal data protected by professional secrecy, i.e., patient data.

In this case, there is no evidence that the individuals whose personal data was encrypted on the servers and other devices of the SPZOZ in P. suffered any material damage. Nevertheless, the mere risk of a breach of confidentiality of their data may constitute non-material damage (harm). Individuals affected by the breach may at least feel apprehensive about losing control over their personal data, identity theft or identity fraud, discrimination, or ultimately financial loss. As indicated by the District Court in Warsaw in the judgment of August 6, 2020, case file XXV C 2596/19, the fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of *Natsionalna agentsia za prihodite* (C-340/21) emphasized that “[a]rt. 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a data subject experiences as a result of a breach of this regulation, may in itself constitute ‘non-material damage’ within the meaning of this provision.” Moreover, the lack of access to this data creates the risk of limited access to medical documentation, which may significantly hinder or even prevent the proper provision of medical services to a specific individual, consequently posing a real risk to the health and even life of the patient.

The long duration of the breach of personal data protection regulations by the SPZOZ in P. is considered an aggravating circumstance for the President of the Office. The Administrator did not conduct a risk analysis related to the processing of personal data, thus failing to fulfill the obligation imposed on him, which is regulated in the aforementioned regulation. Considering that the application of the cited legal act began on May 25, 2018, it should be acknowledged that the state of violation of the provisions of Regulation 2016/679 in this regard has been ongoing since that time.

Regarding the violation of Article 34(1) of the aforementioned regulation, it should be assumed that in this case, the violation of the provisions has been occurring since the date of the identification of the breach of personal data protection (February 10, 2022) and continues due to the failure to notify the individuals concerned about its occurrence. Due to the Administrator's failure to fulfill the obligation imposed on him in this regard, there is a situation where the aforementioned individuals have no knowledge of the incident, which consequently means that they cannot take any remedial actions.

2. Intentional or unintentional nature of the breach (Article 83(2)(b) of Regulation 2016/679).

According to the Guidelines of the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by the EDPB on May 25, 2018), intent “includes both knowledge and deliberate action, in connection with the characteristics of the prohibited act.” The Administrator made a conscious decision not to notify the individuals concerned about the breach of personal data protection. There is no doubt that the Administrator, processing personal data in connection with the conducted activity, should possess knowledge in the field of personal data protection, including the consequences of identifying a breach of personal data protection resulting in a high risk of infringement of the rights or freedoms of individuals. Being aware of this, the Administrator, however, decided to refrain from notifying the individuals concerned.

Taking into account the findings in the case subject to the resolution of this decision, it should be stated that the Administrator committed a conscious failure to take actions that would fulfill the

obligation imposed on him, as referred to in Article 34(1) of Regulation 2016/679. Thus, this constitutes a significant circumstance affecting the severity of the administrative fine.

In the case of violations of the provisions of Article 25(1), Article 32(1) and (2) of Regulation 2016/679, resulting in a breach of the principle of integrity and confidentiality and the principle of accountability (respectively Article 5(1)(f) and Article 5(2) of Regulation 2016/679), the President of the Office did not find any intentional action by the Administrator.

As indicated in the Guidelines of the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679, adopted on October 3, 2017 (17/PL WP 253), "(...) 'unintentionality' means the lack of intent to cause a breach, despite the failure of the administrator/data processor to fulfill the due diligence required by law."

As a result of the security audit conducted in (...) 2022, covering (...) it should be stated that the Administrator did not ensure an appropriate level of data security processed within the utilized resources; however, this action cannot be attributed to intent, characterized by, among other things, deliberate action aimed at causing a breach of the provisions of Regulation 2016/679, and at most, this action can be assessed as lacking due diligence in fulfilling the obligations imposed on the Administrator. The SPZOZ in P. implemented and applied technical and organizational measures, which should be assessed as insufficient to ensure the security of data processing in information systems, but the Administrator's conduct in this regard cannot be characterized as intentional, aimed at violating personal data protection regulations.

Therefore, it should be stated that the Administrator unintentionally violated the provisions on personal data protection, i.e., Article 5(1)(f) and (2), Article...

25 para. 1 and Article 32 para. 1 and 2 of Regulation 2016/679.

3. Actions taken to minimize the damage suffered by the data subjects (Article 83 para. 2 lit. c of Regulation 2016/679).

As indicated above, in this case, there is no evidence that the data subjects suffered material damage. However, the mere risk of a breach of confidentiality of their data constitutes non-material damage (harm) for them.

In this case, the Administrator did not take appropriate actions to minimize any potential damage suffered by the aforementioned individuals, including failing to notify the data subjects accordingly. The Administrator's inaction in this regard deprived the aforementioned individuals of the opportunity to independently respond to potential threats associated with the possible use of their data by unauthorized persons.

Thus, the above-mentioned omission of the Administrator in the described scope should be considered as a circumstance that burdens the assessment of the imposed administrative monetary penalty.

4. Categories of personal data affected by the breach (Article 83 para. 2 lit. g of Regulation 2016/679). The personal data affected by the breach of the provisions of Regulation 2016/679 belonged to special categories of personal data referred to in Article 9 para. 1 of Regulation 2016/679. They included data concerning the health of patients, including children and individuals with special needs (e.g., elderly persons, disabled persons, etc.). Furthermore, the breach involved data of patients and employees of SPZOZ in P., such as: first name, last name, date of birth, bank account number, residential or temporary address, phone number, PESEL number, salary data, series and number of the identity card.

It should be emphasized that the aforementioned scope of data is associated with a high risk of violation of the rights or freedoms of the natural persons affected by the breach. Above all, it is necessary to consider how sensitive the data from the perspective of the data subject were processed in the aforementioned systems that were affected by the ransomware attack. The possibility of unauthorized access to medical data may result in discrimination against the individual whose data is involved, and thus may lead to a violation of the personal rights of the data subject.

Moreover, the unauthorized disclosure of such categories of data as the PESEL identification number along with the first name and last name, which unequivocally identify a natural person, can realistically and negatively affect the protection of the rights or freedoms of that person. As indicated by the

Provincial Administrative Court in Warsaw in its judgment of July 1, 2022, case reference II SA/Wa 4143/21, “in the case of a breach of such data as first name, last name, and PESEL number, identity theft or forgery is possible, resulting in negative consequences for the individuals whose data is involved.”

As stated in the EROD Guidelines 04/2022 on the calculation of administrative monetary penalties under the GDPR (version 2.1; adopted on May 24, 2023), hereinafter: Guidelines 04/2022, “Regarding the requirement to take into account the categories of personal data affected by the breach (Article 83 para. 2 lit. g of the GDPR), the GDPR clearly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 of the GDPR and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the individual whose data is involved (e.g., data concerning location, data concerning private communication, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are involved in the breach or the more sensitive the data is, the greater weight the supervisory authority may assign to this factor.” In determining the amount of the administrative monetary penalty, the President of the Office found no grounds to consider mitigating circumstances affecting the final amount of the penalty. All the criteria listed in Article 83 para. 2 lit. a)-j) of Regulation 2016/679, in the opinion of the supervisory authority, constitute either aggravating circumstances or are merely neutral.

Also, applying the criterion mentioned in Article 83 para. 2 lit. k) of Regulation 2016/679 (requiring consideration of any other aggravating or mitigating factors applicable to the circumstances of the case), no mitigating circumstances were found, only neutral ones.

Other circumstances indicated below, referred to in Article 83 para. 2 of Regulation 2016/679, after assessing their impact on the identified breach in this case, were deemed by the President of UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

1. Degree of responsibility of the Administrator considering the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83 para. 2 lit. d of Regulation 2016/679).

The Guidelines 04/2022 adopted on May 24, 2023, indicate that when considering this criterion, “the supervisory authority must answer the question of the extent to which the administrator did everything that could be expected, considering the nature, purposes, or scope of processing and in light of the obligations imposed on him by the regulation.”

The President of the Office stated in this case that SPZOZ in P. violated the provisions of Articles 32 para. 1 and 2 of Regulation 2016/679. In his opinion, the administrator bears a high degree of responsibility for failing to implement appropriate measures.

technical and organizational measures that would prevent violations of personal data protection. It is evident that in the context of the nature, purpose, and scope of personal data processing, the Administrator did not do everything that could have been expected of him, thus failing to fulfill the obligations imposed on him by the provisions of Article 32(1) and (2) of Regulation 2016/679.

In this case, this circumstance constitutes the essence of the violation itself and is not merely a factor influencing—mitigating or aggravating—its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Article 32 of Regulation 2016/679 cannot be considered by the President of the Office as a circumstance that could additionally influence a stricter assessment of the violation and the amount of the administrative fine imposed on the Administrator.

2. Any relevant prior violations by the Administrator or the processor (Article 83(2)(e) of Regulation 2016/679). The President of the Office did not find any relevant prior violations of Regulation 2016/679 by the SPZOZ in P., therefore there are no grounds to treat this circumstance as aggravating.

However, it is the duty of every administrator to comply with the law (including provisions concerning personal data protection), which means that the absence of prior violations of personal data protection cannot be considered a mitigating circumstance when imposing sanctions.

3. The degree of cooperation with the supervisory authority to remedy the violation and mitigate its

potential negative effects (Article 83(2)(f) of Regulation 2016/679). The Administrator properly fulfilled his procedural obligations during the administrative proceedings that concluded with the issuance of this decision. Furthermore, after the occurrence of the personal data breach, the Administrator took specific actions to clarify the circumstances related to the incident, including conducting a security audit and implementing measures to minimize the risk of a recurrence of the violation. These actions constituted the fulfillment of the obligation imposed on the Administrator, and therefore cannot be considered a mitigating circumstance, especially since the SPZOZ in P. selected these measures without conducting a risk analysis, which means that the Administrator is unable to determine or demonstrate that the aforementioned security measures are appropriate and will ensure protection of the processed personal data, including health-related data, adequate to the risks associated with their processing by an entity providing health care services.

4. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). The President of the Office identified the violation by the Administrator of the personal data protection regulations as a result of a report of a personal data breach made by the SPZOZ in P. In making the report, the Administrator was fulfilling a legal obligation, and therefore there are no grounds to consider this fact as a mitigating circumstance. As indicated by the EDPB in Guidelines 04/2022 on the calculation of administrative fines under the GDPR (p. 32; version 2.1; adopted on May 24, 2023), "According to Article 83(2)(h), the manner in which the supervisory authority became aware of the violation may be a significant aggravating or mitigating factor. In assessing this aspect, particular weight may be given to the question of whether the administrator or processor reported the violation voluntarily, and if so, to what extent, before the supervisory authority was informed of the violation through—for example—a complaint or investigation. This circumstance is irrelevant when the administrator is subject to specific reporting obligations regarding violations (such as the obligation to report a personal data breach specified in Article 33). In such cases, the fact of making a report should be considered a neutral circumstance."

5. Compliance with previously applied measures in the same case, as referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Before issuing this decision, the President of the Office did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the Administrator in the case at hand, which means that the Administrator had no obligation to take any actions related to their application, and such actions, if assessed by the President of the Office, could have had an aggravating or mitigating impact on the assessment of the identified violation.

6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Independent Public Health Care Team based in P. did not inform whether it applies approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. Their adoption, implementation, and application are not, however, as stipulated by the provisions of Regulation 2016/679, mandatory for administrators and processors, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments could be taken into account in favor of the Administrator as measures guaranteeing a higher than standard level of protection for the processed personal data.

7. Financial benefits obtained directly or indirectly in connection with the violation or losses avoided. (art. 83 sec. 2 lit. k of Regulation 2016/679).

The President of the Office did not find that the Administrator derived any financial benefits or avoided any losses in connection with the violation. Therefore, there are no grounds to consider this circumstance as aggravating for the Administrator. The existence of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, the failure of the Administrator to achieve such benefits, as a natural state independent of the violation and its effects, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the wording of Article 83 sec. 2 lit. k) of Regulation

2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" – that is, those that occurred on the part of the entity reporting the violation.

The President of the Office, thoroughly considering the matter at hand, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the imposed administrative monetary penalty.

Taking into account all the circumstances discussed above, the President of the Personal Data Protection Office deemed that imposing an administrative monetary penalty on the Administrator is necessary and justified by the weight, nature, and scope of the violations attributed to the Administrator. It should be stated that applying any other corrective measure provided for in Article 58 sec. 2 of Regulation 2016/679, particularly limiting to a warning (Article 58 sec. 2 lit. b) of Regulation 2016/679), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the Administrator would not commit further negligence in the future.

Regarding the amount of the administrative monetary penalty imposed on the Administrator, it should be noted that given the fact that SPZOZ in P. is a unit of the public finance sector – Article 102 of the Personal Data Protection Act applies, which limits the amount (to 100,000 PLN) of the administrative monetary penalty that can be imposed on a unit of the public finance sector.

In the opinion of the President of the Office, the imposed administrative monetary penalty fulfills, in the established circumstances of this case, the functions referred to in Article 83 sec. 1 of Regulation 2016/679, i.e., it will be effective, proportional, and deterrent in this individual case. According to the President of the Office, the penalty imposed on the Administrator will be effective, as it will lead to a situation in which the Administrator will implement such technical and organizational measures that will ensure the processed data a level of security corresponding to the risk of violation of the rights and freedoms of the data subjects and the severity of the threats associated with the processes of processing such personal data. Thus, the effectiveness of the penalty is equivalent to the guarantee that the Administrator, from the moment of concluding this proceeding, will approach the requirements set by the personal data protection regulations with the utmost diligence.

The applied administrative monetary penalty is also proportional to the identified violation, especially regarding its weight, effect, the circle of affected individuals, and the high risk of negative consequences that they may suffer in connection with the violation. In the opinion of the President of the Office, the administrative monetary penalty imposed on the Administrator will not constitute an excessive burden for him. The amount of the penalty has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of violation of the Administrator's obligations, while on the other hand, does not create a situation in which the necessity of its payment would lead to negative consequences in the form of a significant deterioration of the Administrator's financial situation.

In the opinion of the President of the Office, the Administrator should and is able to bear the consequences of his negligence in the area of data protection, hence the imposition of a penalty in the amount of 40,000 PLN (forty thousand zlotys) is fully justified.

In the opinion of the President of the Office, the administrative monetary penalty will serve, in these specific circumstances, a repressive function, as it will be a response to the Administrator's violation of the provisions of Regulation 2016/679, but also a preventive function, as it will contribute to preventing future violations of the Administrator's obligations arising from the personal data protection regulations. In the opinion of the President of the Office, the imposed monetary penalty meets the criteria referred to in Article 83 sec. 1 of Regulation 2016/679, due to the weight of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679 – especially the principle of confidentiality expressed in Article 5 sec. 1 lit. f) of this legal act.

The purpose of the imposed penalty is to ensure that the Administrator complies with the provisions of Regulation 2016/679 in the future.

In this factual and legal state, the President of the Personal Data Protection Office decided as stated in the operative part.

[1] Guidelines of the European Data Protection Board (EDPB) 9/2022 on reporting personal data breaches in accordance with the GDPR of March 23, 2023, version 2.0, p. 24.

[2] Guidelines of the European Data Protection Board (EDPB) 01/2021 on examples concerning

notification of personal data breaches adopted on December 14, 2021, version 2.0 (hereinafter "EDPB Guidelines 01/2021").

[Print article](#)

[Metadata](#)

Provider:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2024-06-13

Information entered by:

Łukasz Sierdziński

2024-06-25 14:23:02

Last modified by:

Natalia Tołwińska

2024-08-29 08:18:45